PQC DAILY STUDY SERIES

Comparativo dos Padrões PQC do NIST: ML-KEM vs. ML-DSA vs. SLH-DSA

Day 42 | Category: Conceitos Fundamentais de PQC Date: 2026-10-27 | DAILY MONITORING

Comparativo dos Padrões PQC do NIST: ML-KEM vs. ML-DSA vs. SLH-DSA

Após os mergulhos profundos nos padrões PQC individuais do NIST, é hora de uma análise comparativa. Compreender as vantagens e desvantagens entre ML-KEM (CRYSTALS-Kyber), ML-DSA (CRYSTALS-Dilithium) e SLH-DSA (SPHINCS+) é crucial para engenheiros e arquitetos de segurança que os implementarão. Esses algoritmos servem a propósitos criptográficos diferentes e possuem características de performance muito distintas.

Função Criptográfica Principal

> A diferença mais fundamental reside em sua função criptográfica. Um serve para estabelecer segredos, enquanto os outros dois servem para verificar autenticidade.

- **ML-KEM (Kyber):** Um **Mecanismo de Encapsulamento de Chaves (KEM)**. Seu propósito é estabelecer de forma segura um segredo compartilhado entre duas partes através de um canal inseguro. Não é usado para assinatura. Em protocolos de internet, ele substitui o Diffie-Hellman de curva elíptica (ECDH).
- **ML-DSA (Dilithium):** Um **Algoritmo de Assinatura Digital (DSA)**. Seu propósito é criar uma assinatura digital para verificar a autenticidade e a integridade de uma mensagem ou dado. Ele substitui algoritmos como RSA, ECDSA e EdDSA para assinar certificados e mensagens.
- **SLH-DSA (SPHINCS+):** Também um **Algoritmo de Assinatura Digital (DSA)**. Assim como o ML-DSA, é usado para assinaturas digitais. No entanto, sua segurança é baseada em princípios matemáticos diferentes (funções de hash vs. reticulados estruturados), o que leva a um perfil de performance distinto.

Métricas Chave e Comparação de Performance

A performance é um fator crítico para a aplicabilidade no mundo real, especialmente em protocolos de internet sensíveis à latência. A tabela abaixo resume as principais métricas para o nível de segurança recomendado (NIST Nível 1/2).

Métrica	ML-KEM (Kyber-768)	ML-DSA (Dilithium-2)	SLH-DSA (SPHINCS+-128s)
Caso de Uso Principal	Troca de Chaves (ex: TLS, VPNs)	Assinaturas de Propósito Geral (ex: X.509, JWTs)	Assinaturas de Alta Garantia (ex: Firmware, CAs)
Problema Subjacente	Module Learning with Errors (MLWE)	Module Learning with Errors (MLWE)	Segurança de Funções de Hash
Tamanho da Chave Pública	~1.184 bytes	~1.312 bytes	~32 bytes (muito pequena!)
Tamanho da Chave Privada	~2.400 bytes	~2.528 bytes	~64 bytes (muito pequena!)
Tamanho da Assinatura/Criptograma	~1.088 bytes (Criptograma)	~2.420 bytes (Assinatura)	~7.856 bytes (muito grande!)
Velocidade de Assinatura	N/A (Encapsulamento é rápido)	Muito Rápida	Extremamente Lenta
Velocidade de Verificação	N/A (Decapsulamento é rápido)	Rápida	Rápida

Principais Conclusões da Comparação:

- **Domínio dos Reticulados (ML-KEM/ML-DSA):** Para a maioria dos casos de uso comuns, como handshakes TLS e assinatura de código em geral, a família CRYSTALS oferece um perfil balanceado e altamente eficiente, com chaves pequenas e operações rápidas.
- **SPHINCS+ para Confiança Conservadora:** A força do SLH-DSA está em sua premissa mínima de confiança — ele depende apenas da segurança de sua função de hash subjacente. Isso o torna uma excelente escolha para cenários offline e de alta garantia, como a assinatura de CAs raiz ou de firmware, onde sua lentidão para assinar e o tamanho grande da assinatura são desvantagens aceitáveis em troca de sua postura de segurança conservadora.
- **O Tamanho Importa:** A diferença prática mais significativa é o tamanho da assinatura. Uma assinatura ML-DSA tem ~2.4 KB, enquanto uma assinatura SLH-DSA tem quase 8

> KB. Para protocolos que transmitem muitas assinaturas, isso tem um impacto direto na largura de banda.

Aplicabilidade em Protocolos de Internet

- **TLS 1.3:** O ML-KEM é a principal escolha para o mecanismo de troca de chaves pós-quântico, frequentemente em um modo híbrido com X25519 inicialmente. O ML-DSA será usado para assinar os certificados apresentados pelos servidores.
- **SSH & VPNs (WireGuard, IKEv2):** Similarmente ao TLS, o ML-KEM é usado para estabelecer o canal seguro, enquanto o ML-DSA é usado para autenticar o servidor/peers.

  - **Assinatura de Código & Atualizações de Software:** O ML-DSA é o favorito para assinar software e firmware devido à sua velocidade. O ML-DSA pode ser usado para a raiz de confiança ou firmware crítico, onde a velocidade de verificação é mais importante que a velocidade de assinatura.

Auto-avaliação

1. Você está projetando um aplicativo de chat seguro que precisa estabelecer sessões criptografadas. Qual algoritmo PQC é a escolha apropriada para esta tarefa?
2. Uma Autoridade Certificadora (AC) precisa assinar um certificado raiz que será válido por décadas. A maior preocupação é com a segurança a longo prazo e a natureza conservadora do algoritmo, e a velocidade de assinatura não é um problema. Qual algoritmo é o mais adequado?
3. Por que o ML-KEM não é utilizado para assinar documentos digitais?